



Introduction to Cryptography

Lecture 8. Random Bit Generation and Stream Ciphers

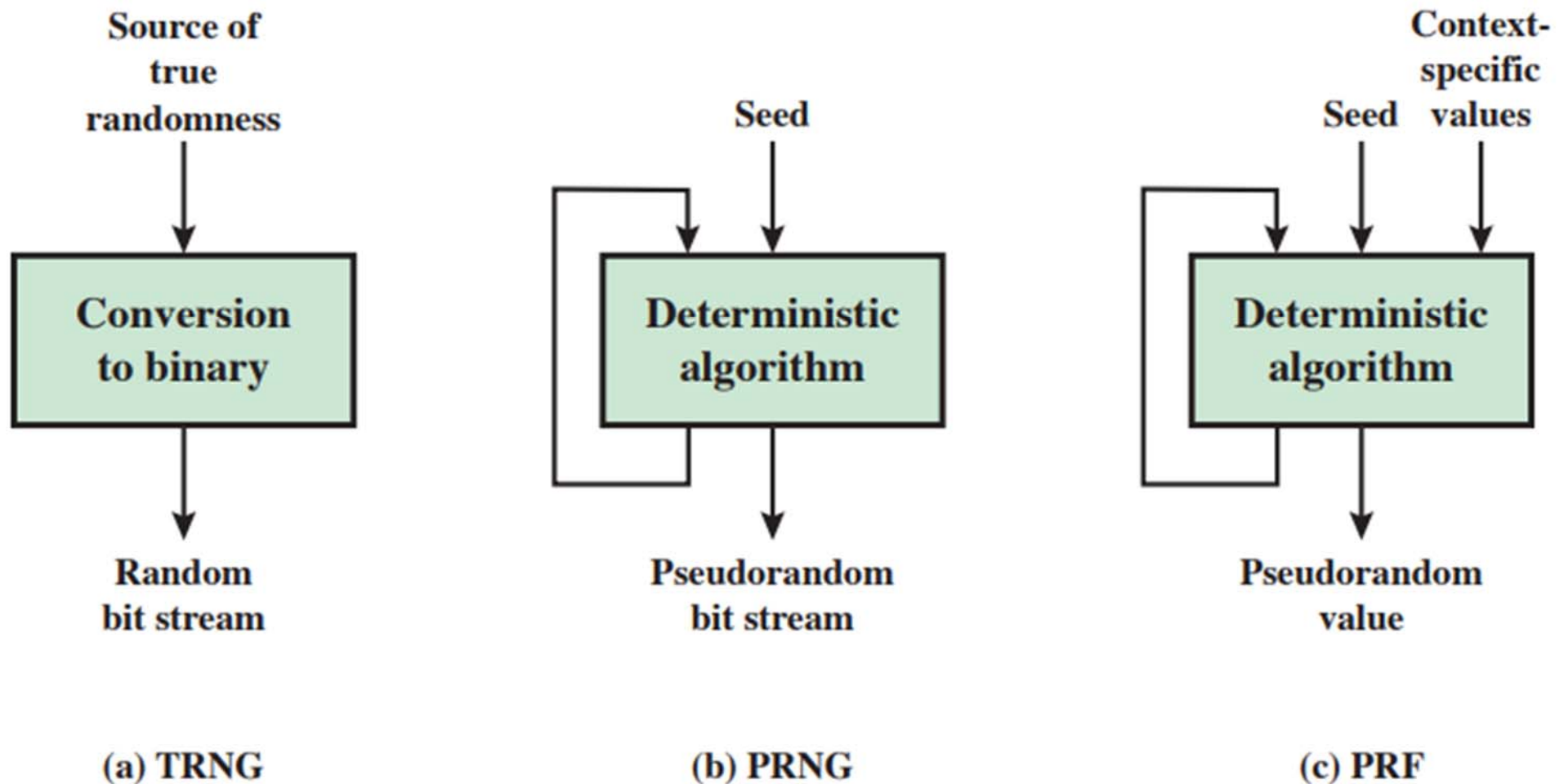
Dr. Tsì-Uí ik, Professor
Network Optimization Lab (NOL)
Department of Computer Science
National Yang Ming Chiao Tung University



Random Number Generators

- Two strategies for generating random bits or random numbers
 - Pseudorandom number generators (PRNGs) or deterministic random bit generators (DRBGs)
 - True random number generators (TRNGs) or non-deterministic random bit generators (NRBGs)
 - RNG-related NIST documents:
 - SP 800-90A: RNG using DRBG (Jun. 2015)
 - SP 800-90B: ES (Entropy Sources) used for RBG (Jan. 2018)
 - SP 800-90C: how to combine 90A and 90B (Apr. 2016)
 - SP 800-22: Statistical Test Suite (Apr. 2010)
- Two requirements for a sequence of random numbers
 - Randomness: uniform distribution and independence
 - Unpredictability
- PRNGs should pass tests of randomness.

Types of Random Numbers





Randomness

- Three randomness characteristics
 - Uniformity: the occurrence of a zero or one is equally likely
 - Scalability: any test applicable to a sequence can also be applied to subsequences extracted at random
 - Consistency: the behavior of a generator must be consistent across starting values.
- SP 800-22 lists 15 separate tests of randomness.
 - Frequency test: the numbers of 0 and 1 are approximately the same
 - Runs test: the number of runs of 0 and 1 is as expected for a random sequences
 - Maurer's universal statistical test: the number of bits between matching pattern
 - ...

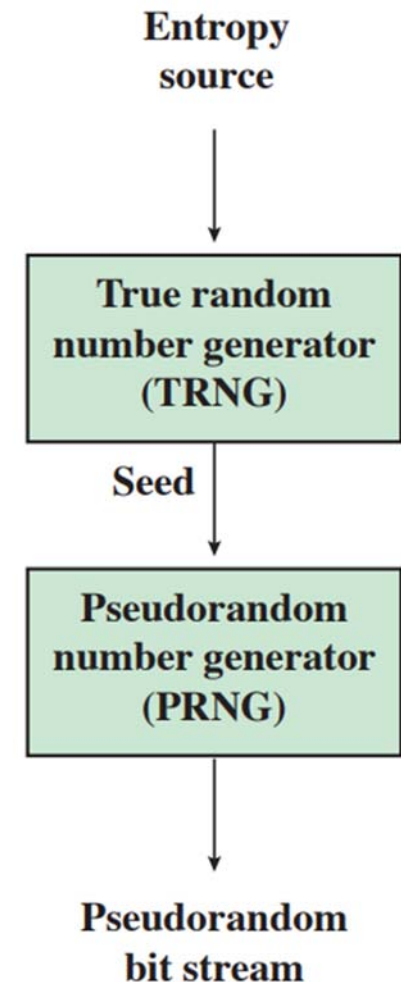


Unpredictability

- A stream of random numbers should have properties of unpredictability
 - Forward unpredictability: If the seed is unknown, the next output bit in the sequence should be unpredictable.
 - Back unpredictability: It is not feasible to determine the seed from knowledge of any generated values.

Seed Requirement

- The seed is critical information to the PRNG, and it is suggested that the seed is generated by a TRNG.
- It is not practical to use TRNG to generate keystream of bits due to the overhead of transmission.
- TRNG may produce a binary string with some bias. So, RNF is used to remedy the bias.
- The generation of TRNG may not fast enough due to the hardware limitation.





Categories of PRNGs

- Purpose-built algorithm
- Algorithms based on existing cryptographic algorithms
 - Symmetric block ciphers
 - Asymmetric ciphers
 - Hash functions and message authentication codes



Linear Congruential Generators

- Four parameters
 - Modulus $m : m > 0$
 - Multiplier $a : 0 < a < m$
 - Increment $c : 0 \leq c < m$
 - Seed $X_0 : 0 \leq X_0 < m$
- An iterative equation to generate random numbers
$$X_{n+1} = (aX_n + c) \bmod m$$
- The modulus m should be nearly equal to the maximum representable nonnegative integer, e.g., 2^{31} .



Evaluate Random Number Generators

- Three tests were proposed
 - T1: should generate a full-period number sequence
 - T2: should appear random
 - T3: can be implemented efficiently with 32-bit arithmetic
- $a = 7^5 = 16807$ for use in the IBM 360 family
- Good for statistical and simulation mission, but the algorithm is not secure

Blum Blum Shub (BBS) Generator

- Choose two large prime numbers p and q with $p \equiv q \equiv 3 \pmod{4}$, and let $n = p \times q$.
- Choose a random number s relatively prime to n .
- The BBS algorithm below generates a sequence of bits B_i .
$$X_0 = s^2 \bmod n$$
$$\text{for } i = 1 \text{ to } \infty$$
$$X_i = (X_{i-1})^2 \bmod n$$
$$B_i = X_i \bmod 2$$
- Considered as the strongest public proof of the cryptographic strength of any purpose-built algorithm
- Cryptographically Secure PseudoRandom Bit Generator (CSPRBG): pass the next-bit test
 - There is not a polynomial-time algorithm that, on input of the first k bits of an output sequence, can predict the $(k + 1)$ -st bit with probability significantly greater than $1/2$.
- The security of BBS is based on the difficulty of factoring n .

PRNG based on Block Ciphers

- CTR is recommended in NIST SP 800-90A, ANSI X9.82, and RFC 4086

while (*len(temp)* < *ReqNumBits*) **do**

$$V = (V + 1) \bmod 2^{128}$$

$$\text{output} = E(\text{key}, V)$$

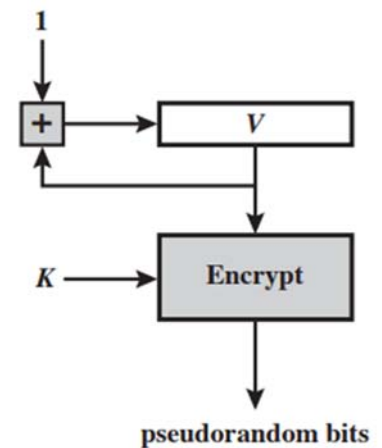
$$\text{temp} = \text{temp} \parallel \text{output}$$

- OFB is recommended in X9.82 and RFC 4086.

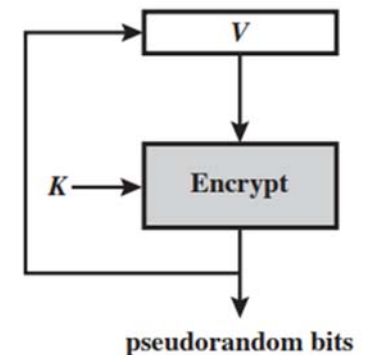
while (*len(temp)* < *ReqNumBits*) **do**

$$V = E(\text{key}, V)$$

$$\text{temp} = \text{temp} \parallel V$$



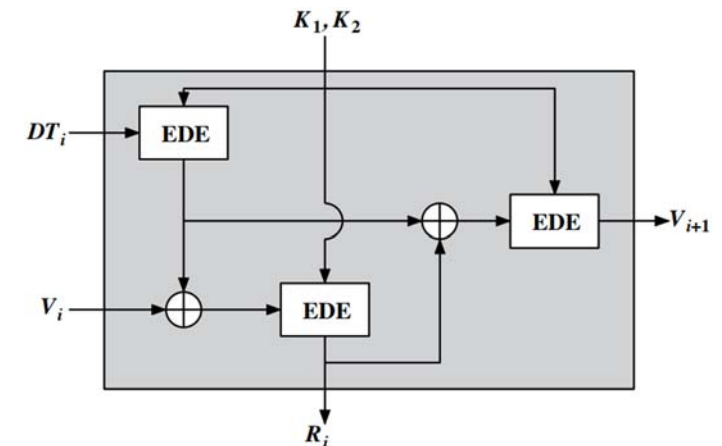
CTR PRBG



OFB PRBG

ANSI X9.17 PRNG

- Composed of three 3DES's
 - DT_i : 64-bit date/time value of the i -th stage
 - V_i : 64-bit seed value of the i -th stage
 - R_i : 64-bit pseudorandom number generated by the i -th stage
 - K_1 and K_2 : 3DES keys for each stage
- Input two pseudorandom numbers. One is a 64-bit representation of the current date and time. The other is a 64-bit seed value
- All three 3DES's use the 56-bit keys, which must be kept secret.
- The output consists of 64-bit pseudorandom number and a 64-bit seed value.

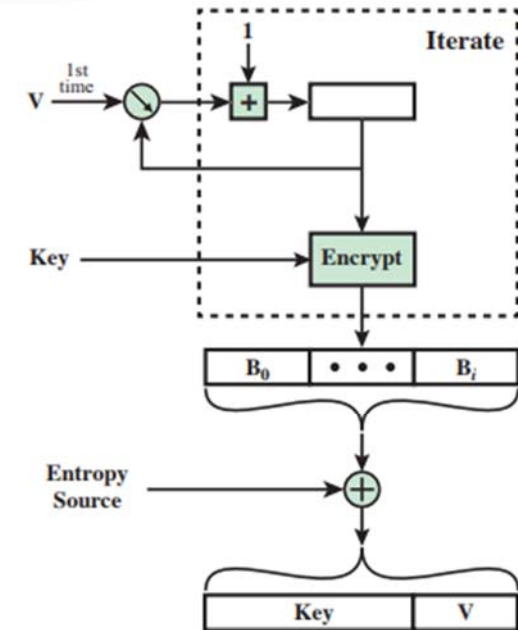


$$R_i = EDE([K_1, K_2], [V_i \oplus EDE([K_1, K_2], DT_i)])$$

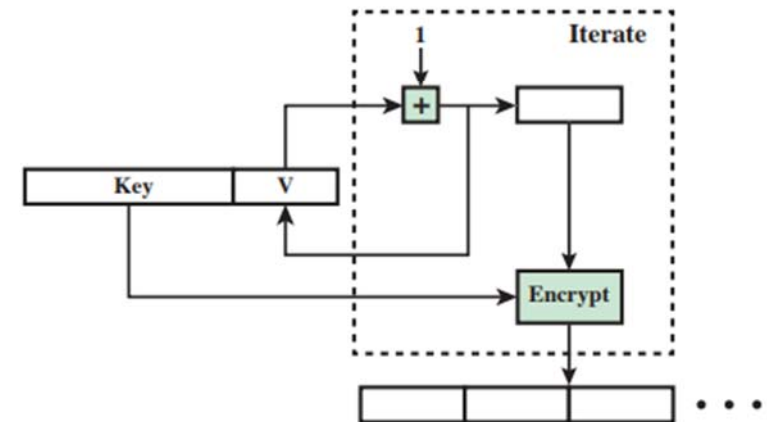
$$V_{i+1} = EDE([K_1, K_2], [R_i \oplus EDE([K_1, K_2], DT_i)])$$

CTR_DRBG (NIST SP 800-90A)

- Part of the hardware random number generator implemented on recent Intel processor chips
- The DRBG assumes that an entropy source is available to provide random bits.
- The block encryption algorithm can be 3-keys 3DES or 128/192/256-bits AES
 - *outlen*: output block length
 - *keylen*: key length
 - *seedlen*: the length of the seed that is a string of bits input to the DRBG ($seedlen = outlen + keylen$)
 - *reseed_interval*: the length of the encryption key that is the maximum number of output blocks generated before updating the seed



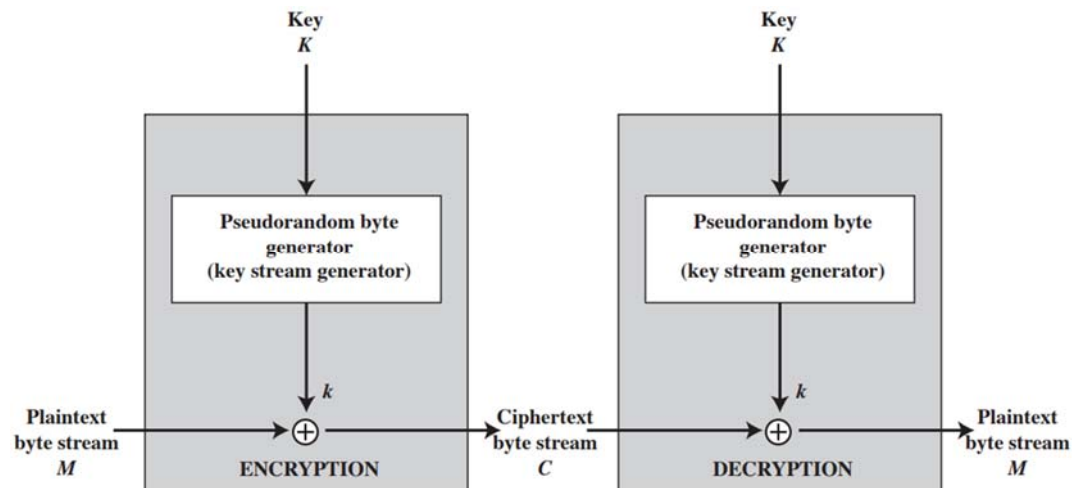
(a) Initialize and update function



(b) Generate function

Stream Ciphers

- A stream cipher typically encrypts plaintext one byte at a time, although it also may be designed to operate on 1 bit or on units larger than a byte.
- It is like the OTP but with a PRNG with a key K to generate the key stream.
- The key length is recommended at least 128 bits.
- A stream cipher is faster and needs far less codes in implementation than a block cipher.
- A stream cipher is better than a block cipher to protect a stream of data such as a data communication channel.
- However, from the aspect of key reuse, block ciphers are better than stream ciphers.





RC4

- A designed in 1987 for RSA Security
 - Was a trade secret by RSA Security
 - Was anonymously posted on the Internet in Sep. 1994
 - The period of the cipher is greater than 10^{100}
- Used in WPA (WiFi Protected Access) of IEEE 802.11, and optional for SSH (Secure Shell) and Kerberos
- Variable key size with byte-oriented operation
 - A 1~256-byte key is used to initialize a 256-byte state vector $S[0..255]$ that contains a permutation of all 8-bit numbers from 0 to 255 at all times.
 - For encryption/decryption, a byte k is selected from S systematically.
 - As the k is generated, S are permuted again.

RC4 Algorithm

Initialization of S

- Initialize variables
 - for** $i = 0$ **to** 255 **do**
 - $S[i] = i$
 - $T[i] = K[i \bmod \text{keylen}]$
- Initial permutation
 - $j = 0$
 - for** $i = 0$ **to** 255 **do**
 - $j = (j + S[i] + T[i]) \bmod 256$
 - $\text{swap}(S[i], S[j])$

Generation of the key stream

- Stream generation
 - $i, j = 0$
 - while** (*true*)
 - $i = (i + 1) \bmod 256$
 - $j = (j + S[i]) \bmod 256$
 - $\text{swap}(S[i], S[j])$
 - $t = (S[i] + S[j]) \bmod 256$
 - $k = S[t]$ $\leftarrow$ the output



Weakness of RC4

- Many analyzing methods of attacking RC4 have been published, but none of them is practical.
- A problem is reported on the key generation of WEP protocol for use as input to RC4, but it is not relevant to RC4 itself.
- In 2007, a fundamental vulnerability in the RC4 key scheduling was reported.
- In 2013, it was reported that the biases in RC4 keystream can be exploited to recover repeatedly encrypted plaintext.
- In 2013, NIST in SP 800-52 (guidelines for TLS) prohibited the use of RC4 for government use.
- In 2015, IETF in RFC 7465 prohibited the use of RC4 in TLS.



Entropy Sources

- TRNG's rely on unpredictable natural processes to produce randomness, such as pulse detectors of ionizing radiation events, gas discharge tubes, and leaky capacitors.
 - Intel has developed a commercial chip on thermal noise by sampling the output of a coupled pair of inverters.
 - LavaRnd is an open source project utilizing inexpensive cameras.
 - Keyboard timing, mouse movement, ...
- RFC 4086 lists possible sources of randomness
 - Sound/video input
 - Disk devices
- “random.org”, an online randomness service, delivers random sequences securely over the Internet.



Comparison of PRNGs and TRNGs

	Pseudorandom Number Generators	True Random Number Generators
Efficiency	Very efficient	Generally inefficient
Determinism	Deterministic	Nondeterministic
Periodicity	Periodic	Aperiodic



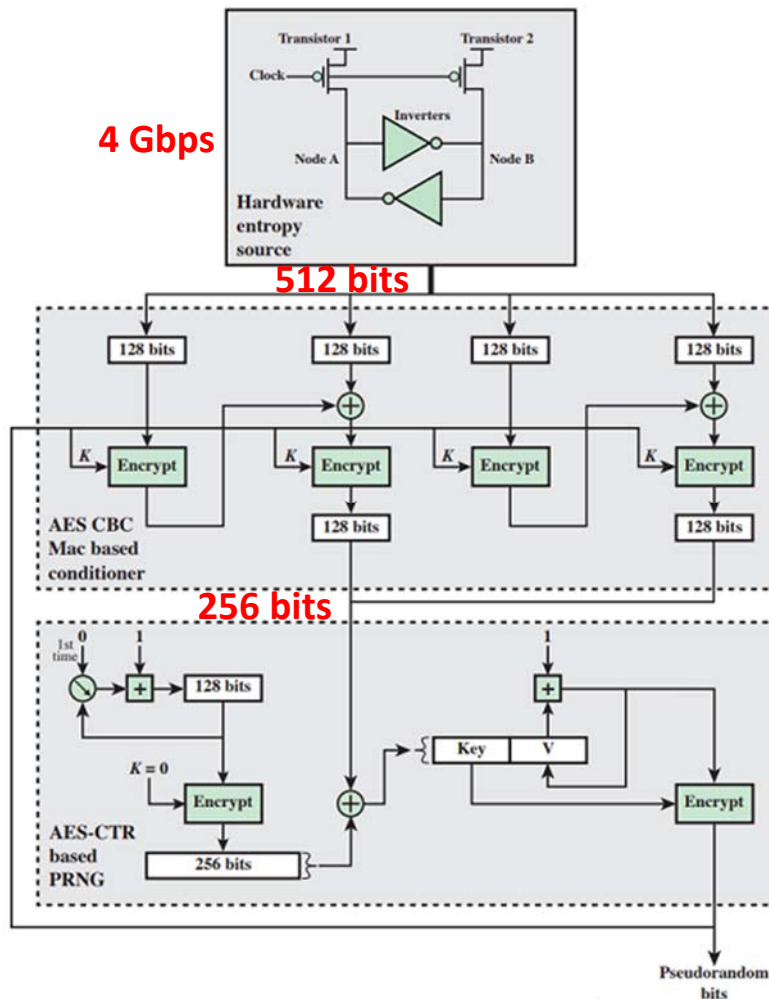
Conditioning

- A TRNG may produce an output that is biased in some way, such as having more ones than zeros or vice versa.
- It is assumed that hardware sources of random bits may be bias. “conditioning algorithms” are applied to further randomize/scramble the bits to eliminate bias and increase entropy.
- The two most common approaches are the use of a hash function or a symmetric block cipher.
 - Linux uses four entropy sources: mouse and keyboard activity, disk I/O operations, and specific interrupts. Bits are generated from these four sources and stored in a pooled buffer. Bits are read from the buffer and passed to SHA-1 to generate random bits.
 - AES is used to scramble the TRNG bits, e.g., in SP 800-90B and the Intel implementation.

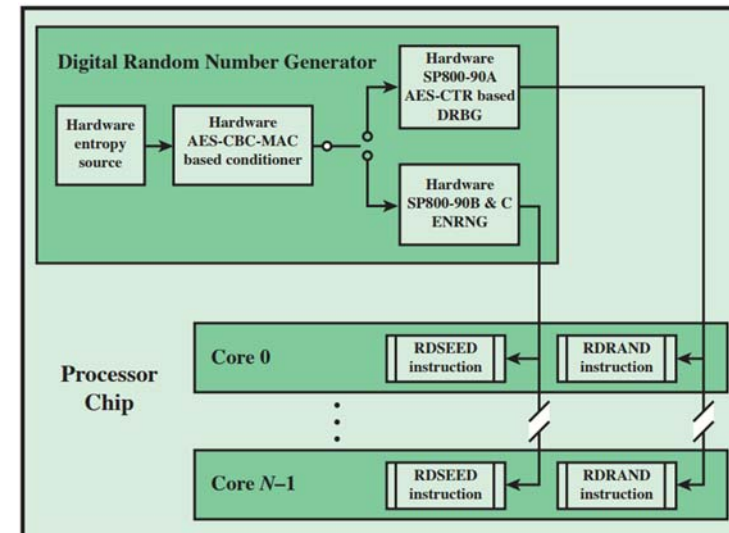
Health Testing

- Repetition Count Test
 - The probability of a H -bits sample repeating C times in a row
 $\Pr[C \text{ identical samples in a row}] \leq (2^{-H})^{C-1}$
 - The test keeps looking for consecutive identical samples. If the count reaches some cutoff value C , an error condition is raised.
 - A parameter $W \leq (2^{-H})^{C-1}$ is set at some very small value to determine $C = \left\lceil 1 + \frac{-\log W}{H} \right\rceil$. For example, $W = 2^{-30}$ and $H = 7.3$ bits per sample would have a cutoff value C of $\left\lceil 1 + \frac{30}{7.3} \right\rceil = 6$.
- Adaptive Proportion Test
 - Record a sample value and then observes N successive sample values.
 - If the record value is observed at least C times, then an error condition is reported.

Intel Digital Random Number Generator (DRNG)



- The first commercially available TRNG offered on new multicore chips since May 2012 achieves bit production rates comparable with that of PRNGs.
- Pure hardware implementation





Thanks for Listening